

Actividad 1.

Análisis y planificación del pentest

Dirigido a: Hacker Woman Council – Ethical Hacking

Ejecutado por: **Atziri Isabel Ramos Rizo**

Fecha: 01 de septiembre 2026

Objetivo: Aurora Market

Clasificación: CONFIDENCIAL

Tabla de contenido

Tabla de contenido	1
1. Objetivos del Pentest.....	2
2. Alcance.....	3
3. Autorización y condiciones	3
4. Tipo de pentest	3
5. Planificación	3
6. Fases del Pentest	4
7. Investigación	5

1. Objetivos del Pentest

1. Reconocimiento de la tecnología involucrada en la aplicación y definición de controles de seguridad.
2. Evaluación de tecnología. Ejecutando pruebas en cada una de las capas de la aplicación.
3. Encontrar los riesgos potenciales, hacer recomendaciones sobre estos y las vulnerabilidades.

2. Alcance

- Página web de Aurora Market
- Método de autenticación
- Información almacenada

Fuera de alcance:

- Redes sociales
- Correos electrónicos
- Equipos personales
- Proveedores externos
- Sistemas ajenos a la página web

3. Autorización y condiciones

Permisos requeridos:

- Solicitud de cuenta de usuario final.
- Realizar pruebas de penetración sobre la página web de Aurora Market.
- Conocer el tipo de información que almacenan en la base de datos.

Condiciones acordadas:

- La evaluación de la aplicación se realizará entre lunes y viernes en horario de la madrugada.

4. Tipo de pentest

El tipo de pentest es Gray-Box, dado que el conocimiento de la infraestructura o tecnología es limitado, se hará una simulación de ataque con la información parcial que se tiene, identificando amenazas internas y externas.

5. Planificación

Objetivos: **Acceder a la página web de Aurora Market y ejecutar pentest.**

Alcance: **Página web Aurora Market y tipo de información almacenada.**

Permisos y condiciones: **Usuario con rol final, ejecución de pruebas entre lunes y viernes en horario de madrugada.**

Metodología para utilizar: **OWASP**

Recopilación de información previa: **URL de página web, método de autenticación, tipo de información almacenada.**

Recursos necesarios: **herramientas de pentest, calculadora de riesgos e impactos.**

Programación del pentest: **de lunes a viernes en la madrugada.**

6. Fases del Pentest

1. Reconocimiento: Una vez que se tiene identificada la URL del portal de Aurora Market, se inicia con la etapa de buscar más activos involucrados en el entorno; subdominios, tecnologías, tipos de usuarios, etc.

- **Se identifica que la autenticación de los usuarios es solamente con usuario y contraseña, además que no se tiene vigencia de contraseña. También se identifican diferentes tipos de usuarios con diferentes privilegios.**
- **Se identifica una base de datos.**

2. Análisis de vulnerabilidades: después de lo identificado en el reconocimiento se inicia con el análisis de cada tecnología, buscando áreas de oportunidad a nivel sistema y seguridad para identificar posibles vulnerabilidades que pongan en riesgo la información y la aplicación.

Se identifican los siguientes riesgos:

- **Los usuarios no se autentican con un doble factor de autenticación.**
- **No se cuenta con vigencia de contraseña.**
- **No se cuenta con certificado vigente en la URL.**
- **Posible inyección de código desde la autenticación y hacia la base de datos.**
- **Mala configuración de datos de usuarios.**

3. Explotación: Intentar vulnerar los riesgos identificados en las tecnologías.

4. Post-explotación: Se realizan pruebas dentro de la tecnología involucrada, tratando de explotar las vulnerabilidades. Desde el desarrollo, configuración y controles.

- **Se intenta hacer inyección de código desde el formulario de autenticación, validando también si tiene buena gestión de errores.**

- Una vez dentro de la aplicación se intenta escalar privilegios y cambiar registros de los roles y privilegios de los usuarios.

5. Informe:

Se realizó la evaluación de riesgo partiendo del tipo de información que involucra a la empresa; dado que es información de usuarios y datos financieros se clasifica como sensible, por lo tanto, el riesgo es más alto en cada vulnerabilidad identificada.

Módulo	Riesgo	Resultado
Autenticación	Autenticación: Los usuarios no cuentan con vigencia de contraseñas y autenticación en dos pasos.	Medio. El nivel de exposición es relevante, pero se puede manejar.
Gestión de pruebas	Inyección de código desde formulario de autenticación	Medio. El nivel de exposición es relevante, pero se puede manejar.
Gestión de la administración	Mala configuración por la escalación de privilegios, se puede filtrar información de usuarios o comprometiendo la integridad de los datos.	Medio. El nivel de exposición es relevante, pero se puede manejar.

Acciones recomendadas:

- Es necesario priorizar y remediar para reducir el riesgo y evitar que este se materialice.
- Asignar responsables esta semana.
- Validar los controles detectivos.
- Convertir las remediaciones en un plan de acción de 30 días.

7. Investigación

Metodología utilizada: OWASP

Esta metodología es útil para este proyecto porque su enfoque es para aplicaciones web y móviles, muestra los problemas de seguridad más comunes; por ejemplo, el control de acceso que es parte de los riesgos identificados. Además, cuenta con documentación a nivel global del significado de cada vulnerabilidad y como puede corregirse. Finalmente, tiene recursos extras como calculadore de riesgos contra impactos y análisis de aplicaciones web.